

Kebutuhan API Live Chat dan SSO Dashboard untuk Integrasi Clara

Versi	v1.1
Status	Draft untuk disepakati bersama Tim Live Chat
Konsumen API	Clara Backend
Penyedia API	Backend Live Chat
Metode sinkronisasi conversation	GET saja
Sumber akun dashboard	Clara
Channel internal Clara	live_chat

1. Tujuan

Dokumen ini menjelaskan:

1. API yang perlu disediakan Tim Live Chat agar Clara dapat mengambil conversation dan message.
2. SSO agar agent dapat masuk ke Dashboard Live Chat menggunakan akun Clara.
3. Identitas yang menentukan pemilik conversation dan pengirim setiap message.

Integrasi menggunakan pola pull:

```
Customer menggunakan Live Chat Website
|
Backend Live Chat menyimpan conversation dan message
|
Clara Backend melakukan GET ke API Live Chat
|
Clara menyimpan conversation, message, dan lead
```

Alur login Dashboard Live Chat:

```
Agent membuka Dashboard Live Chat
|
Dashboard mengarahkan agent ke login Clara
|
Clara mengautentikasi agent
|
Backend Live Chat menerima identitas terverifikasi
|
Dashboard membuat session Live Chat milik agent
```

Pembatasan GET hanya berlaku untuk API sinkronisasi conversation dari Live Chat ke Clara. Proses SSO mengikuti Authorization Code Flow dan membutuhkan pertukaran token server-to-server menggunakan POST. Password, session cookie, dan access token tidak boleh dikirim melalui URL atau query parameter.

Clara tidak meminta webhook, akses database, cookie browser, atau token session customer.

2. Kebutuhan dari Tim Live Chat

Tim Live Chat perlu memberikan:

1. Base URL API untuk staging dan production.
2. Endpoint GET untuk mengambil conversation beserta messages.
3. Kredensial server-to-server untuk Clara.
4. Contoh response JSON asli.
5. Filter incremental berdasarkan waktu atau cursor.
6. Mekanisme pagination.
7. Informasi rate limit dan timeout.
8. Daftar status HTTP dan format error.
9. Identitas website/site jika satu sistem melayani lebih dari satu website.
10. Dukungan SSO Dashboard Live Chat menggunakan akun Clara.
11. Penyimpanan `claraUserId` sebagai identitas agent.
12. Informasi assignee conversation dan identitas pengirim message.

3. Endpoint yang Diharapkan

Rekomendasi endpoint:

```
GET /api/v1/conversations
```

Contoh request:

```
GET /api/v1/conversations?updated_after=2026-09-01T00:00:00Z&limit=100
Authorization: Bearer <LIVE_CHAT_API_KEY>
Accept: application/json
```

Jika menggunakan cursor:

```
GET /api/v1/conversations?cursor=next-page-token&limit=100
Authorization: Bearer <LIVE_CHAT_API_KEY>
Accept: application/json
```

Nama endpoint dan query parameter boleh mengikuti standar internal Tim Live Chat, tetapi kemampuan incremental sync dan pagination wajib tersedia.

4. Authentication API Conversation

Rekomendasi autentikasi:

```
Authorization: Bearer <API_KEY>
```

Ketentuan keamanan:

- API wajib menggunakan HTTPS.
- API key hanya digunakan server-to-server.
- API key tidak boleh ditanam di widget atau JavaScript browser.
- API key harus dapat dicabut dan dirotasi.
- Kredensial staging dan production harus berbeda.
- API key hanya diberi izin baca conversation dan message.
- Response error tidak boleh membocorkan API key, stack trace, atau data sensitif.

Jika Tim Live Chat menggunakan mekanisme autentikasi lain, dokumentasinya perlu diberikan kepada Tim Clara.

4.1 Pemisahan Credential

Credential API conversation adalah service credential milik backend Clara, bukan credential user Dashboard Live Chat. API key menentukan site/organization yang boleh dibaca dan tidak menentukan agent pemilik conversation.

Rekomendasi mapping internal Clara:

```
LIVE_CHAT_API_KEY -> siteId -> organizationId
```

Satu credential sebaiknya hanya memiliki akses ke satu site/organization. Jika satu credential dapat mengakses beberapa site, Backend Live Chat wajib memvalidasi bahwa `site_id` termasuk scope credential tersebut.

4A. SSO Dashboard Live Chat

Dashboard Live Chat menggunakan akun yang dikelola Clara. Tim Live Chat tidak membuat atau menyimpan password agent secara terpisah.

Protokol yang direkomendasikan adalah OAuth 2.0 Authorization Code Flow dengan PKCE atau OpenID Connect. Nama endpoint final dapat mengikuti standar Clara dan disepakati saat implementasi.

Contoh alur:

```
GET <CLARA_SSO_BASE_URL>/authorize
?client_id=live-chat-dashboard
&redirect_uri=<LIVE_CHAT_CALLBACK_URL>
&response_type=code
&scope=openid%20profile%20email
&state=<RANDOM_STATE>
&code_challenge=<PKCE_CHALLENGE>
&code_challenge_method=S256
```

Setelah login berhasil, Clara mengarahkan browser ke callback yang sudah didaftarkan:

```
GET <LIVE_CHAT_CALLBACK_URL>?code=<ONE_TIME_CODE>&state=<RANDOM_STATE>
```

Backend Live Chat kemudian menukar authorization code secara server-to-server. Authorization code wajib sekali pakai, berumur pendek, dan terikat pada `client_id`, `redirect_uri`, serta PKCE verifier.

Ketentuan SSO:

- Redirect URI harus menggunakan HTTPS dan didaftarkan secara eksplisit.
- state wajib dibuat acak dan diverifikasi untuk mencegah login CSRF.
- PKCE menggunakan S256.
- Password Clara tidak boleh diterima atau disimpan oleh Live Chat.
- Session cookie Clara tidak boleh dibagikan ke domain Live Chat.
- Client secret dan token tidak boleh diletakkan di frontend atau URL.
- User nonaktif atau organization tidak valid wajib ditolak.
- Tim Live Chat membuat session dashboard sendiri setelah identitas berhasil diverifikasi.
- Logout Live Chat minimal menghapus session Live Chat; mekanisme single logout dapat disepakati terpisah.

Catatan: endpoint SSO di atas adalah kontrak target. Clara saat ini memiliki login JWT internal, tetapi belum bertindak sebagai OAuth/OIDC provider. Endpoint authorization-code SSO perlu disediakan oleh Tim Clara sebelum integrasi SSO diuji.

4A.1 Identitas User dari Clara

Identitas terverifikasi minimal yang diterima Backend Live Chat:

```
{
  "sub": "8a1d0f7c-1d45-4c0a-9058-2d2b58544e70",
  "name": "Andi",
```

```

"email": "andi@company.com",
"role": "sales",
"organizationId": "77bd68a7-fd22-4db8-a1b7-9505d18531b4",
"teamId": "7e79fc33-708f-489d-b678-4eebf0cbecc9",
"isActive": true
}

```

Aturan:

- sub adalah UUID user Clara yang stabil dan menjadi claraUserId di Live Chat.
- Live Chat tidak boleh menggunakan nama atau email sebagai primary identifier.
- Hak akses Dashboard Live Chat ditentukan dari role, organizationId, dan kebijakan akses yang disepakati.
- Perubahan nama atau email tidak boleh membuat akun agent baru.
- Agent hanya boleh melihat data organization yang sama dengan identitas SSO-nya.
- Role awal yang dikenali adalah sales, manager, head, dan superadmin; permission detail perlu disepakati sebelum production.

5. Query Parameter

Parameter	Wajib	Contoh	Keterangan
updated_after	Ya untuk request awal/incremental	2026-09-01T00:00:00Z	Mengambil conversation yang berubah setelah waktu tertentu
cursor	Ya untuk halaman lanjutan	next-page-token	Token pagination dari response sebelumnya
limit	Disarankan	100	Jumlah maksimum conversation per halaman
site_id	Kondisional	website-main	Dibutuhkan jika API melayani beberapa website/tenant

Aturan:

- Request pertama menggunakan updated_after.
- Halaman berikutnya menggunakan cursor yang dikembalikan API.
- Clara tidak mengirim updated_after dan cursor secara bersamaan, kecuali dokumentasi API menentukan lain.
- Timestamp wajib menggunakan ISO-8601 dengan timezone, disarankan UTC (Z).

6. Response Sukses

Contoh response yang dibutuhkan Clara:

```

{
  "data": [
    {
      "id": "conv-123",
      "siteId": "website-main",
      "title": "Budi",
      "status": "open",
      "createdAt": "2026-09-01T09:50:00Z",
      "updatedAt": "2026-09-01T10:05:00Z",
      "visitor": {
        "id": "visitor-123",
        "externalUserId": "customer-789",
        "name": "Budi",
        "email": "budi@example.com"
      },
      "assignee": {

```

```

      "claraUserId": "8a1d0f7c-1d45-4c0a-9058-2d2b58544e70",
      "name": "Andi",
      "email": "andi@company.com"
    },
    "messages": [
      {
        "id": "msg-001",
        "senderType": "customer",
        "senderId": "visitor-123",
        "senderClaraUserId": null,
        "senderName": "Budi",
        "text": "Halo, saya ingin bertanya.",
        "sentAt": "2026-09-01T10:00:00Z"
      },
      {
        "id": "msg-002",
        "senderType": "sales",
        "senderId": "agent-987",
        "senderClaraUserId": "8a1d0f7c-1d45-4c0a-9058-2d2b58544e70",
        "senderName": "Andi",
        "text": "Tentu, ada yang bisa dibantu?",
        "sentAt": "2026-09-01T10:01:00Z"
      }
    ]
  },
  "pagination": {
    "nextCursor": "next-page-token",
    "hasMore": true
  }
}

```

Response halaman terakhir:

```

{
  "data": [],
  "pagination": {
    "nextCursor": null,
    "hasMore": false
  }
}

```

7. Contract Conversation

Field	Tipe	Wajib	Aturan
id	string	Ya	ID conversation stabil, unik, dan tidak berubah
siteId	string	Kondisional	Wajib jika API melayani lebih dari satu website
title	string/null	Tidak	Nama atau judul conversation
status	string	Ya	Minimal mendukung open dan closed
createdAt	datetime	Ya	ISO-8601 dengan timezone
updatedAt	datetime	Ya	Berubah setiap conversation atau message berubah
visitor	object/null	Tidak	Identitas minimum visitor
assignee	object/null	Ya	Agent aktif yang menangani conversation; null jika belum ditugaskan
messages	array	Ya	Daftar message milik conversation

updatedAt merupakan field penting untuk incremental sync. Jika message baru masuk, nilai ini wajib ikut berubah.

8. Contract Visitor

Field	Tipe	Wajib	Aturan
id	string	Disarankan	ID visitor stabil jika tersedia
externalUserId	string/null	Tidak	ID akun customer website jika customer login
name	string/null	Tidak	Nama visitor
email	string/null	Tidak	Email visitor jika memang dikumpulkan secara sah

Jangan mengirim data profil yang tidak dibutuhkan Clara.

`visitor.id` tetap digunakan untuk visitor anonim. `externalUserId` hanya dikirim jika identitas customer telah diverifikasi oleh Backend Live Chat. Jangan mengirim cookie, password, session token, atau token login customer.

8A. Contract Assignee

Field	Tipe	Wajib	Aturan
claraUserId	UUID	Ya jika assigned	Nilai sub user Clara dari SSO
name	string/null	Tidak	Nama tampilan agent
email	string/null	Tidak	Email tampilan; bukan primary identifier

Aturan ownership:

- `assignee.claraUserId` menentukan agent yang sekarang menangani conversation.
- Clara memvalidasi bahwa user masih aktif dan berada di organization yang sama dengan site.
- Jika `assignee=null`, user tidak ditemukan, user nonaktif, atau organization berbeda, Clara menyimpan conversation sebagai `unassigned`.
- Reassignment mengubah `assignee`, tetapi tidak mengubah identitas pengirim message lama.
- Live Chat tidak boleh menentukan ownership berdasarkan nama atau email saja.

9. Contract Message

Field	Tipe	Wajib	Aturan
id	string	Ya	ID message unik, stabil, dan tidak berubah
senderType	enum	Ya	Hanya customer atau sales
senderId	string	Ya	ID pengirim stabil pada sistem Live Chat
senderClaraUserId	UUID/null	Kondisional	Wajib untuk sales; null untuk customer
senderName	string	Ya	Nama pengirim, maksimal 255 karakter
text	string	Ya	Plain text, maksimal 5.000 karakter
sentAt	datetime	Ya	ISO-8601 dengan timezone

Contoh mapping:

```
Pesan visitor/customer -> senderType=customer, senderId=visitor.id
Pesan operator/agent   -> senderType=sales, senderClaraUserId=user Clara
```

`assignee.claraUserId` menunjukkan pemilik conversation saat ini, sedangkan `message.senderClaraUserId` menunjukkan agent yang benar-benar mengirim message. Keduanya boleh berbeda setelah reassignment.

Clara tidak membutuhkan raw HTML, DOM, cookie, token session, screenshot, password, maupun attachment binary pada versi pertama.

Jika pesan hanya berisi attachment, Tim Live Chat dapat mengirim representasi plain text seperti:

```
[Attachment: invoice.pdf]
```

10. Pagination dan Urutan Data

- Maksimum yang direkomendasikan adalah 100 conversation per halaman.
- `nextCursor` harus opaque; Clara tidak perlu memahami isi cursor.
- Data harus diurutkan secara konsisten berdasarkan `updatedAt`, lalu `id` sebagai tie-breaker.
- Cursor tidak boleh melewati data ketika beberapa conversation memiliki `updatedAt` yang sama.
- `hasMore=true` wajib disertai `nextCursor` yang tidak kosong.
- Halaman terakhir mengembalikan `hasMore=false` dan `nextCursor=null`.

11. Incremental Sync dan Idempotency

Clara akan:

1. Menyimpan waktu atau cursor sync terakhir yang berhasil.
2. Mengambil conversation yang baru atau berubah.
3. Menyimpan conversation berdasarkan `organizationId + siteId + conversation.id`.
4. Menyimpan message berdasarkan `siteId + conversation.id + message.id`.
5. Melewati message yang sudah pernah tersimpan.
6. Menyimpan checkpoint baru hanya setelah seluruh halaman berhasil diproses.

Karena itu:

- `conversation.id` tidak boleh digunakan ulang untuk conversation lain.
- `message.id` tidak boleh berubah ketika endpoint dipanggil ulang.
- `assignee.claraUserId` wajib ikut berubah ketika conversation dipindahkan ke agent lain.
- Response untuk filter dan cursor yang sama harus konsisten selama periode pagination.
- Mengembalikan data yang sama beberapa kali diperbolehkan; kehilangan data tidak diperbolehkan.

12. Error Contract

Format error yang direkomendasikan:

```
{
  "error": {
    "code": "INVALID_CURSOR",
    "message": "Cursor tidak valid atau sudah kedaluwarsa."
  }
}
```

HTTP	Kondisi	Tindakan Clara
200	Request berhasil	Proses data dan pagination

HTTP	Kondisi	Tindakan Clara
400	Query parameter tidak valid	Hentikan retry dan catat error konfigurasi
401	API key hilang/tidak valid	Hentikan retry dan minta rotasi/perbaiki credential
403	Credential tidak punya akses	Hentikan retry dan perbaiki permission
404	Endpoint tidak ditemukan	Hentikan retry dan periksa URL/version
429	Rate limit terlampaui	Retry mengikuti Retry-After
500-599	Gangguan server	Retry dengan exponential backoff

Untuk response 429, sertakan:

```
Retry-After: 30
```

13. Rate Limit dan Reliability

Tim Live Chat perlu menginformasikan:

- Batas request per menit.
- Timeout yang direkomendasikan.
- Maksimum limit per halaman.
- Masa berlaku cursor jika ada.
- Maintenance window dan jalur eskalasi insiden.

Rekomendasi awal:

```

Polling interval : 30-60 detik
Page limit       : 100 conversation
Request timeout  : 10-30 detik
Retry            : exponential backoff untuk 429 dan 5xx

```

Nilai final mengikuti kapasitas API Live Chat.

14. Security dan Privacy

- Semua komunikasi wajib melalui HTTPS.
- API key disimpan di environment variable atau secret manager.
- Jangan menaruh API key di repository, log, frontend, atau browser extension.
- Terapkan least privilege: read-only untuk conversation dan message.
- Jika memungkinkan, batasi akses berdasarkan IP backend Clara.
- Jangan mencatat full message text di access/error log.
- Jangan mengembalikan cookie, session token, password, OTP, atau header internal.
- Data antar-site/tenant wajib terisolasi.
- Organization ditentukan dari scope service credential dan harus konsisten dengan organizationId agent hasil SSO.
- claraUserId wajib divalidasi sebagai UUID user Clara yang aktif sebelum digunakan sebagai assignee.
- Jangan menggunakan email atau nama sebagai sumber kebenaran ownership.
- Password Clara tidak boleh disalin ke database Live Chat.
- Authorization code harus sekali pakai dan access token harus berumur pendek.
- Redirect URI SSO wajib menggunakan allowlist yang exact match.

- Message harus dikembalikan sebagai plain text untuk mencegah XSS.
- Retention data mengikuti kebijakan perusahaan dan persetujuan customer.

15. Contoh Penggunaan dari Clara

Contoh request manual:

```
curl --request GET \
  --url 'https://live-chat.example.com/api/v1/conversations?updated_after=2026-09-01T00%3A00%3A00Z&limit=100' \
  --header 'Accept: application/json' \
  --header 'Authorization: Bearer <LIVE_CHAT_API_KEY>'
```

Contoh Node.js:

```
const url = new URL("/api/v1/conversations", process.env.LIVE_CHAT_API_URL)
url.searchParams.set("updated_after", lastSuccessfulSync)
url.searchParams.set("limit", "100")

const response = await fetch(url, {
  headers: {
    Accept: "application/json",
    Authorization: `Bearer ${process.env.LIVE_CHAT_API_KEY}`
  }
})

if (!response.ok) {
  throw new Error(`Live Chat API returned HTTP ${response.status}`)
}

const result = await response.json()
```

16. Acceptance Checklist

Integrasi siap diuji jika:

- ☐ Endpoint staging tersedia melalui HTTPS.
- ☐ Clara menerima API key read-only untuk staging.
- ☐ Request hanya menggunakan method GET.
- ☐ Filter `updated_after` atau mekanisme incremental setara tersedia.
- ☐ Pagination cursor tersedia dan terdokumentasi.
- ☐ `conversation.id` stabil dan unik.
- ☐ `message.id` stabil dan unik.
- ☐ `updatedAt` berubah ketika message baru masuk.
- ☐ Semua timestamp memiliki timezone.
- ☐ `senderType` dapat dipetakan ke customer atau sales.
- ☐ Dashboard Live Chat dapat login menggunakan authorization-code SSO Clara.
- ☐ Password dan session cookie Clara tidak disimpan atau dibagikan ke Live Chat.
- ☐ state, PKCE S256, dan allowlist redirect URI sudah diuji.
- ☐ Live Chat menyimpan sub Clara sebagai `claraUserId` agent.
- ☐ `assignee.claraUserId` tersedia atau bernilai null jika unassigned.
- ☐ Message sales memiliki `senderClaraUserId` yang valid.
- ☐ Agent lintas organization ditolak.
- ☐ User Clara yang nonaktif tidak dapat membuat session Live Chat.

- [] Message dikembalikan sebagai plain text.
- [] Response kosong valid dan tidak dianggap error.
- [] Status 401, 403, 429, dan 5xx dapat diuji.
- [] Rate limit dan timeout sudah disepakati.
- [] Contoh response asli sudah diberikan kepada Tim Clara.

17. Informasi yang Perlu Diisi Tim Live Chat

```

Staging Base URL      :
Production Base URL   :
Endpoint Path         :
Authentication Method :
Header Credential     :
Incremental Parameter :
Pagination Method     :
Maximum Page Size     :
Rate Limit            :
Recommended Timeout   :
Cursor Expiration     :
Contact Person        :

Clara SSO Base URL    :
SSO Client ID         :
Allowed Redirect URI   :
Authorization Endpoint :
Token Endpoint         :
JWKS/Introspection URL :
Allowed Clara Roles    :
Live Chat Session TTL :

```

18. Di Luar Scope v1

- Mengirim balasan dari Clara ke Live Chat.
- Membuka atau menutup conversation dari Clara.
- Mengubah assignment agent.
- Mengambil attachment binary.
- Webhook atau method selain GET.
- Sinkronisasi password Clara ke database Live Chat.
- Single logout lintas aplikasi.

Pembatasan method selain GET hanya berlaku pada API sinkronisasi conversation. Endpoint SSO Clara mengikuti protokol OAuth/OIDC dan bukan bagian dari API conversation milik Tim Live Chat. Fitur operasional lainnya dibuat sebagai kontrak terpisah hanya jika nanti benar-benar dibutuhkan.